

BUAP

FACULTAD DE CIENCIAS DE LA COMPUTACIÓN

Nombre: Mendoza Reyes Jose de Jesus
Nombre: Fernández Jiménez Pedro

Semestre: 9no Semestre
Materia: Ingeniería de Software Avanzada
Tarea: Reporte de Entrega del Hito 6 (MVP-6)
Proyecto CIVITAS · 12/11/2026

1. Resumen

CIVITAS es una plataforma de transparencia del mercado inmobiliario de renta, con Puebla como ciudad piloto. Su visión completa abarca un catálogo de zonas, detección de anomalías de precio, verificación de solvencia con pruebas de conocimiento cero (ZK) y una red de datos ciudadanos con IA predictiva.

El MVP-6 (Sprint 6, del 5 al 11 de noviembre de 2026) cumple el hito H6 del plan, el **motor de anomalías v1** (Justo / Inflado / Subprecio), y añade tres correcciones pedidas al cerrar el MVP-5: **todo lo relacionado con usuarios**, **datos de INEGI de todo el estado** y **una interfaz más cuidada**. Este reporte, además, evalúa el producto contra **ISO/IEC 25010:2023** (calidad) y contra las recomendaciones de diseño seguro del **IEEE Center for Secure Design** (secciones 5 y 6).

- **Motor de anomalías (H6):** compara el precio por m² de cada anuncio con el de anuncios parecidos de su misma zona (mediana, MAD y z robusto, ajustado por tipo de inmueble y recámaras). Su primera versión midió 45.7 % de precisión y el checklist la reprobó; tras corregir el método llegó a **86.9 %** (IC 95 %: 85.0 % a 88.6 %) con un recall de 53.2 %. La etiqueta se ve en la ficha y en `/rentas`, y la lista se filtra por etiqueta.
- **Usuarios:** se integró el panel de cuenta de `/mi-cuenta` que aportó el equipo y se verificó el ciclo completo de sesión (registro, cuenta, permiso por rol y cierre de sesión), que antes el smoke nunca recorría.
- **INEGI de todo el estado:** de la capital (498 zonas) se pasó a **2,503 zonas urbanas de los 217 municipios**, con población y viviendas del Censo 2020, nombre oficial de municipio y localidad, y el contorno de cada municipio. Los comercios del DENUE pasaron de 107 mil a 410,693 y las paradas de OpenStreetMap, de 1,075 a 1,211.
- **Interfaz:** menú que se pliega en móvil y marca la sección actual; filtro por municipio con chips de filtros activos; bloque «Quién vive aquí» en la ficha; portada con la forma real del estado; y un mapa que se descarga aparte (la página dejó de cargar megas de contorno dentro de su HTML).
- **Checklist ejecutable etl mvp6:** anomalías (cobertura, muestra, precisión y umbral), consistencia de INEGI (claves, municipios y Censo) y cuentas (hashes y administrador).

El checklist de MVP-6 sale APROBADO, con cuatro avisos que se explican en la sección 7: los precios de renta siguen siendo de demostración (no existe una fuente abierta) y la precisión se mide contra anomalías sembradas por el propio generador, no contra etiquetas humanas. Las zonas, los comercios y las paradas sí son datos reales (INEGI y OpenStreetMap). Se hereda del MVP-5 que las 5 entrevistas de precio y el Plan B siguen pendientes: son tareas de una persona, no de código.

Durante la verificación se encontraron y corrigieron varios problemas: la primera versión del motor no alcanzaba la meta de precisión, con 2,503 zonas el catálogo dejaba zonas fuera sin avisar, una tabla de la ficha quedaba cortada y el DENUE traía teléfono y correo de cada negocio (se guarda recortado). Todo está en la sección 7.

Los objetivos del sprint (requisitos funcionales, no funcionales y criterios para pasar) se resumen en la Figura 1.

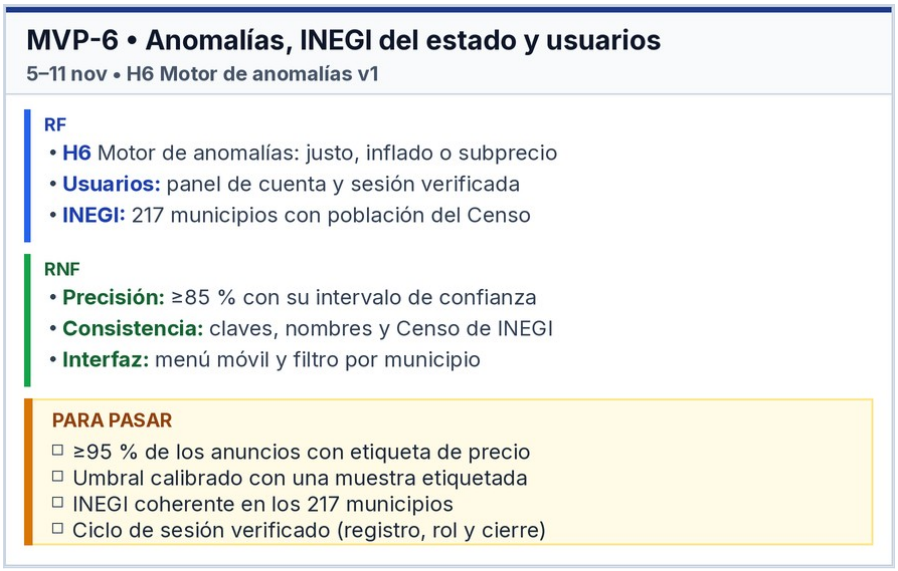


Figura 1. Objetivos del MVP-6. Requisitos funcionales (H6, usuarios e INEGI), requisitos no funcionales (precisión, consistencia e interfaz) y criterios «Para pasar» del Sprint 6, del 5 al 11 de noviembre.

2. Criterios de Aceptación

ID / Requisito	Criterio verificable	Estado	Evidencia
H6. Motor de anomalías	≥95 % de los listados con superficie reciben etiqueta	Cumplido (precios de demostración)	28,772 de 28,772: 27,360 justos, 819 inflados y 593 de subprecio; 28,771 comparados en su propia zona; Fig. 6
H6. Calibración	Umbral del z robusto elegido con una muestra, no a ojo	Cumplido (muestra sembrada)	Umbral 3.5, el más bajo cuya precisión alcanza 85 %; precisión por umbral: 1.5→40 %, 2→56 %, 2.5→70 %, 3→80 %, 3.5→87 %, 4→93 %, 5→96 %
H6. Precisión	≥85 % con el intervalo de confianza a la vista	Cumplido con reservas	86.9 % (IC 95 %: 85.0 % a 88.6 %) sobre 1,412 anomalías detectadas; recall de 53.2 %; medida contra anomalías sembradas, no humanas
H6. Muestra de validación	60 listados etiquetados (el plan prevé etiquetado manual)	Cumplido con reservas	28,772 etiquetas de origen «sembrado»: no sustituyen al etiquetado humano que pide el plan
H6. Etiqueta visible	Cada anuncio muestra su etiqueta; la lista se filtra por ella	Cumplido	Ficha de zona y `/rentas`; `GET /listados-renta?anomalia=inflado`; Fig. 4 y 6
Usuarios	Panel de cuenta integrado y ciclo de sesión verificado	Cumplido	Registro → `/auth/me` → 403 en `/admin/resumen` para un usuario normal → cierre de sesión → el token da 401 (smoke); Fig. 7
INEGI de todo el estado	Zonas de los 217 municipios con población del Censo	Cumplido	2,503 zonas, 217 municipios, 410,693 comercios y 1,211 paradas; `etl mvp2 --fuente real --estado-completo` APROBADO
RNF-CAL. Consistencia de INEGI	CVEGEO de 13 caracteres, municipio y nombre oficial coherentes, ≥95 % con población	Cumplido	0 claves inconsistentes, 0 zonas sin municipio, 0 nombres distintos al catálogo, 0 municipios cuya suma de AGEB supera su población; 99.6 % de zonas con población

ID / Requisito	Criterio verificable	Estado	Evidencia
Interfaz	Menú móvil, filtro por municipio, bloque de población y portada con la forma del estado	Cumplido (verificación en navegador)	Probado a 1440 y 390 px, incluido el tooltip de los «?» con teclado; Fig. 2 a 5 y 8; no se probó en un dispositivo móvil físico
Corre desde cero	Base vacía → migración → carga → validación	Cumplido	8 migraciones aplicadas (001 a 005, 010, 011 y 012); `etl mvp2`, `mvp3`, `mvp4` y `mvp6` APROBADOS; `mvp5` NO APROBADO por lo heredado
Precios reales de renta	Precios de una fuente real	No cumplido	No hay fuente abierta (el ADR-002 prevé captura manual): los precios siguen siendo de demostración y la interfaz lo avisa en cada página
Entrevistas (heredado del MVP-5)	5 hechas y con notas (3 inquilinos, 2 B2B)	Pendiente	0 registradas; la herramienta de captura funciona; las entrevistas las hace una persona
Plan B (heredado del MVP-5)	Plan B escrito en `docs/mvp5/MVP5.md`	Pendiente	El check `plan_b` de `etl mvp5` sigue fallando

Verificación realizada: stack completo con Docker Compose levantado desde cero con datos reales (`etl mvp2 --fuente real --estado-completo --desde-cero`, `mvp3`, `mvp4` y `mvp6` APROBADO; `mvp5` NO APROBADO por lo heredado); suite automatizada (22 suites, 347 pruebas, todas pasan); `scripts/smoke.sh` (Smoke OK, 55 comprobaciones, con el ciclo de sesión real) y la ruta que usará el CI, con datos de prueba en un stack limpio (Smoke OK). No verificado: el CI en GitHub con estas correcciones, un despliegue público y el uso en un dispositivo móvil físico.

3. Evidencias y Funcionalidad

Las capturas corresponden al stack local (http://localhost) con datos reales de INEGI y OpenStreetMap, y con precios de renta de demostración (por eso aparece el aviso amarillo).

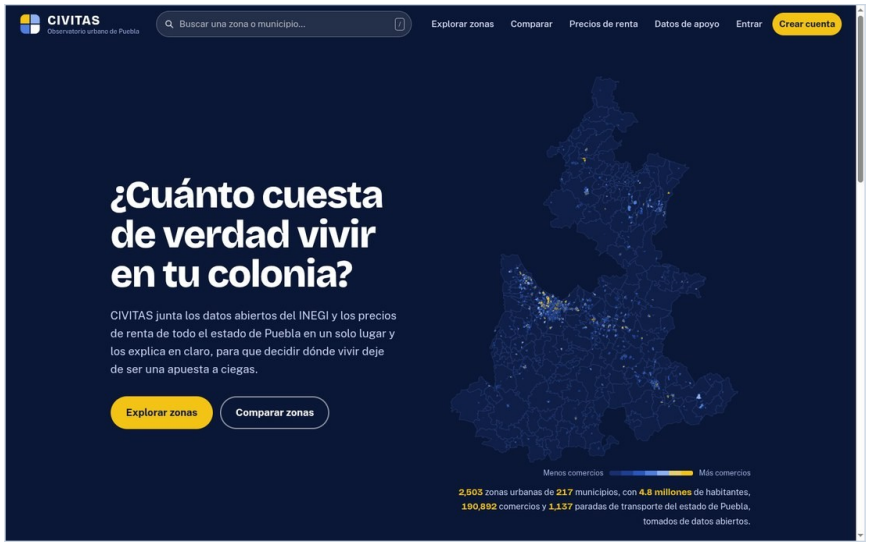


Figura 2. Portada. La silueta son los 217 municipios de Puebla (INEGI) y encima cada zona urbana, coloreada por su número de comercios: la zona metropolitana de la capital brilla en amarillo. Bajo el mapa, las cifras del estado: 2,503 zonas, 4.8 millones de habitantes en zonas urbanas, 190,892 comercios y 1,137 paradas.

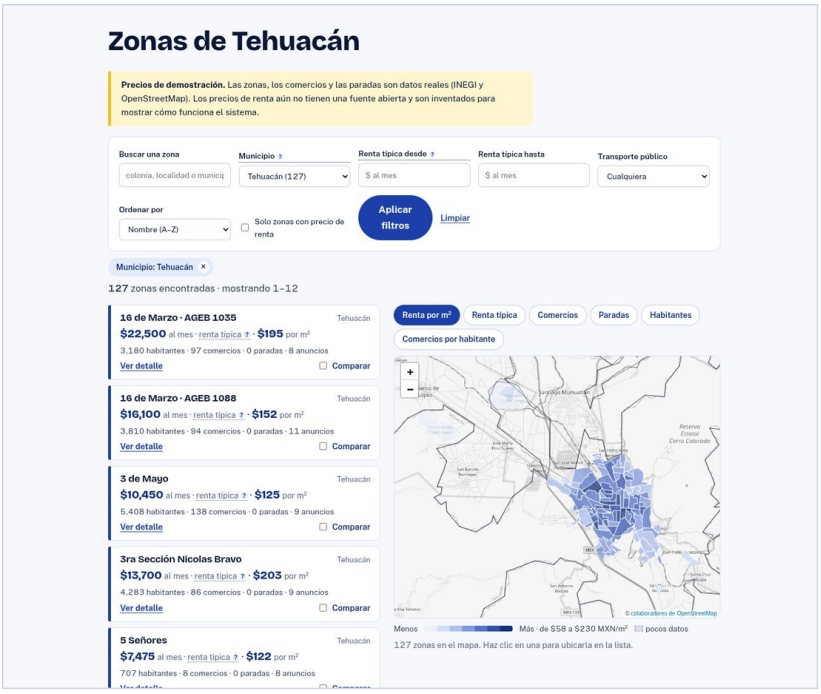


Figura 3. Catálogo de todo el estado, filtrado por municipio. Tehuacán (127 zonas): mapa con la silueta municipal, chip del filtro activo y tarjetas con habitantes, comercios y paradas. El contorno de las zonas se descarga aparte (2.76 MB simplificados en PostGIS) y se reutiliza al paginar.



Figura 4. Ficha de zona con población del Censo. «Centro · AGEB 0408» (Puebla): frase de lectura que dice a qué se compara el precio, indicadores y el bloque «Quién vive aquí» (población, viviendas, habitantes por km² y comercios por cada 1,000 habitantes). La referencia es el municipio o, si tiene menos de 5 zonas con precios, todo el estado.

Indicador	Centro · AGEB 0408 Puebla · Quitar	Centro · AGEB 0279 San Andrés Cholula · Quitar	La Purísima · AGEB 1073 Tehuacán · Quitar
Precio			
Renta típica al mes	$11,950	$8,400	$21,950
Rango normal de rentas	$4,350 – $25,300	$5,975 – $11,800	$13,325 – $31,475
Renta por m²	$213.33	$141.06	$188.58
Frente al promedio de su municipio o del estado	+4.4 % frente a Puebla	−22.6 % frente a San Andrés Cholula	+83.7 % frente a Tehuacán
Lugar por precio (1 = más cara)	30 de 498 en Puebla	20 de 51 en San Andrés Cholula	26 de 127 en Tehuacán
Anuncios de renta	13	15	10
Población			
Habitantes (Censo 2020)	3,047	3,771	3,967
Viviendas habitadas	1,009	1,223	1,012
Habitantes por km²	4,680	3,358	11,892
Comercios por cada 1,000 habitantes	448.3	14.9	262.4
Comercio			
Comercios	1,366	56	1,041
Comercios de mayoreo	91	3	11
Comercios de menudeo	1,275	53	1,030
Comercios por km²	2,098	50	3,121
Transporte			
Paradas de transporte	16	0	0
Paradas por km²	24.6	0.0	0.0
Zona			
Municipio	Puebla	San Andrés Cholula	Tehuacán
Área (km²)	0.65	1.12	0.33

Figura 5. Comparador de 3 zonas de municipios distintos (/comparar). Centro (Puebla), Centro (San Andrés Cholula) y La Purísima (Tehuacán): +4.4 % frente a Puebla, −22.6 % frente a San Andrés Cholula y +83.7 % frente a Tehuacán, y el lugar de cada zona dentro de su propio municipio. Se añadieron las filas de población y de municipio.

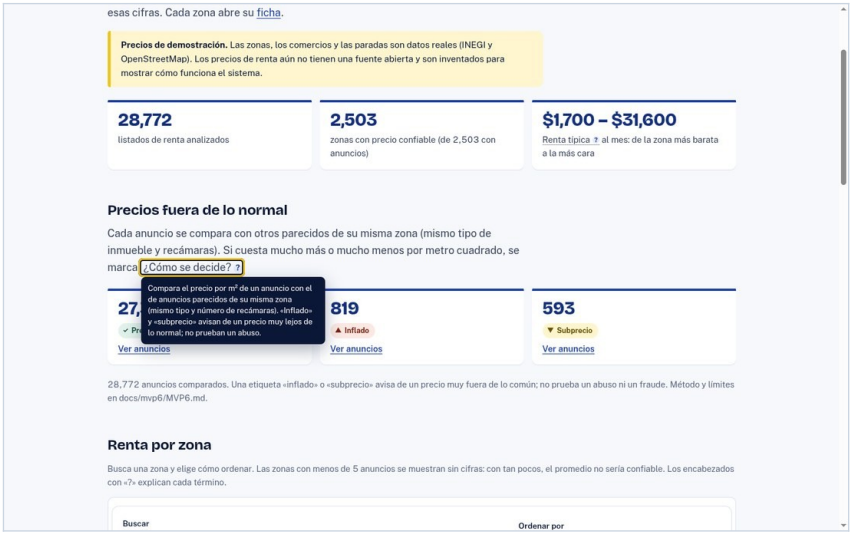


Figura 6. Anomalías de precio en /rentas. Resumen de cuántos anuncios son justos, inflados o de subprecio, con el tooltip del «?» abierto (verificado con teclado en un navegador). Cada anuncio lleva una etiqueta con color, símbolo y texto, y la lista se filtra por etiqueta.



Figura 7. Panel de usuario (/mi-cuenta). Vista con sesión iniciada de una cuenta creada desde el formulario real: accesos rápidos que resaltan el que corresponde al uso previsto, datos de la cuenta y resumen de rentas. El correo solo se muestra aquí, nunca en el panel de administración.

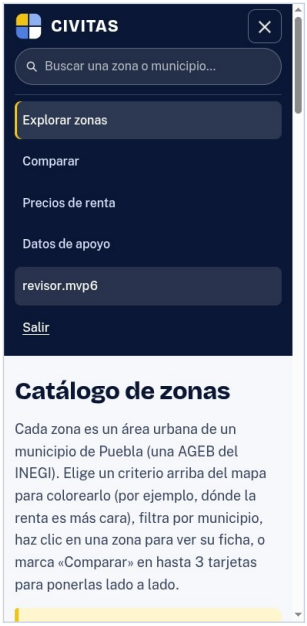


Figura 8. Vista móvil a 390 px. Menú abierto en `/colonias`: se pliega detrás de un botón, se cierra con Escape o al cambiar de página y marca la sección actual.

Resultado de `etl mvp6` (checklist «Para pasar»), tal como lo imprime el ETL:

Criterio	Resultado	Detalle
Método del motor documentado	Cumple	`docs/mvp6/MVP6.md` tiene la sección «Método»
≥95 % de los anuncios etiquetados	Cumple	28,772 de 28,772 (100 %) · justo 27,360, inflado 819, subprecio 593 · comparados en su zona 28,771 y en el estado 1

Criterio	Resultado	Detalle
Muestra etiquetada de ≥60 listados	Aviso	28,772 etiquetas (origen: sembrado): las anomalías las sembró el generador de la demo; el plan pide etiquetado humano, que no sustituye
Precisión ≥85 % con intervalo	Aviso	Precisión 86.9 % (IC 95 %: 85.0 % a 88.6 %) sobre 1,412 anomalías detectadas · recall 53.2 % · exactitud de las tres etiquetas 95.6 % · medida contra anomalías SEMBRADAS
Umbral calibrado con la muestra	Cumple	Umbral 3.5 (el más bajo cuya precisión alcanza 85 %) · precisión por umbral: 1.5→40 % · 2→56 % · 2.5→70 % · 3→80 % · 3.5→87 % · 4→93 % · 5→96 %
CVEGEO de 13 caracteres y prefijo coherente	Cumple	2,503 zonas · 0 con clave inconsistente
Zonas y municipios de INEGI consistentes	Cumple	217 municipios cargados · zonas sin municipio: 0 · con otro nombre que el del catálogo: 0 · municipios cuya suma de AGEB supera su población: 0
≥95 % de las zonas con población del Censo	Cumple	2,493 de 2,503 zonas (99.6 %) · 4,818,777 habitantes en zonas urbanas · el resto lo reserva INEGI por confidencialidad
Cobertura de zonas y municipios	Cumple	2,503 zonas de 217 municipios · 30 zonas piloto (solo del municipio del ADR-001)
Contraseñas con scrypt, sesiones con SHA-256 y un administrador	Aviso	Sin cuentas en la base de la corrida (0 administradoras): no hay contraseñas ni sesiones en claro, pero tampoco administrador
Anomalías sobre precios reales	Aviso	Se calculan sobre listados de DEMOSTRACIÓN (modo fixture): demuestran el método, no el mercado de Puebla

Resultado global: **APROBADO** (ningún criterio falla, cuatro avisos). «Aviso» significa que el criterio se cumple con la limitación indicada.

4. Ficha Técnica y Reproducibilidad

4.1 Stack tecnológico

Capa	Tecnología
Runtime	Node.js 22, pnpm (workspace)
API + ETL	NestJS 10 (pg directo, helmet, Swagger), CLI en TypeScript (`mvp2` a `mvp6`, `recaptura`, `migrar`, `validar*`); motor de anomalías como funciones puras en `api/src/anomalias`
Web	Next.js 15.5.29 (App Router, output standalone) y Leaflet 1.9.4 con lienzo (canvas) y mapa base de OpenStreetMap en grises; tipografías Bricolage Grotesque y Public Sans; `/colonias`, `/comparar`, `/rentas`, `/zonas`, `/mi-cuenta`, `/admin`
Base de datos	PostgreSQL 16 + PostGIS 3.4 (SRID 4326)
Migraciones	SQL versionado (001 … 005, 010, 011 y 012) con checksum; la 011 añade localidad, población y viviendas, y la tabla `municipios`; la 012, `listados_anomalias` y `mvp6_validaciones`
Datos	INEGI (Marco Geoestadístico dic. 2025, Censo 2020, DENUE) y OpenStreetMap (ODbL); `scripts/preparar-datos-reales.py` los descarga y recorta
Infraestructura	Docker Compose (servicio `recaptura` con el perfil `cron`), Caddy (proxy; HTTPS automático con dominio real); CI con `etl mvp2`, `mvp3`, `mvp4`, `mvp6` y el smoke

4.2 Ejecución

```
cd civitas
python3 scripts/preparar-datos-reales.py     # INEGI de los 217 municipios, DENUE (recortado) y
paradas de OSM
python3 scripts/generar-rentas-demo.py       # rentas de DEMOSTRACIÓN y su muestra etiquetada
docker compose up -d --build                 # db → migrate → api → web → caddy
docker compose run --rm etl mvp2 --fuente real --estado-completo --desde-cero
docker compose run --rm etl mvp3 --fuente fixture --listados
/app/data/raw/rentas-demo/renta_demo_estado.csv
docker compose run --rm etl mvp4             # recaptura (si no hay) + checklist
docker compose run --rm etl mvp6             # anomalías y checklist de MVP-6
```

Los datos reales de INEGI y OpenStreetMap ya vienen en el repositorio (`data/raw`); el primer script solo es necesario para regenerarlos. El DENUE se guarda sin teléfono, correo, sitio web ni razón social. Las rentas de demostración no se versionan: se regeneran con el segundo script. Para usar otra muestra de etiquetas, `--etiquetas archivo.csv` o `CIVITAS_ETIQUETAS_PATH`; para fijar el umbral, `--umbral`.

4.3 Pruebas

```
docker compose --profile test run --rm test    # 22 suites · 347 pruebas
WEB_URL=http://localhost bash scripts/smoke.sh # "Para pasar" MVP-1 a MVP-6 (55 comprobaciones)
```

Las pruebas nuevas cubren el motor (mediana, MAD, piso de σ, ajuste por tipo y recámaras, calibración y métricas), la lectura de etiquetas, la referencia con respaldo al estado y, contra PostGIS, la carga de varios municipios (la cifra reservada del Censo queda nula, los pilotos son solo del municipio del ADR-001) y que el checklist de INEGI **detecta de verdad** una inconsistencia: población de municipio menor que la suma de sus AGEB, nombre oficial distinto, o clave que no mide 13 caracteres en una carga real. Dos pruebas de contrato se actualizaron a propósito: los listados ahora traen municipio y etiqueta, y el mapa pide hasta 3,000 zonas con simplificación.

4.4 Datos cargados

Fuente	Contenido	Volumen
INEGI · MGN (AGEB urbanas)	Zonas con CVEGEO, población y viviendas del Censo 2020, municipio y localidad	2,503 zonas · 217 municipios
INEGI · MGN (municipios)	Contorno, población y viviendas	217 polígonos
INEGI · DENUE	Unidades económicas del estado, recortadas a las columnas que usa el ETL	410,693 (190,892 comercios dentro de las zonas)
OpenStreetMap	Paradas y estaciones de bus y tren	1,211 (1,137 dentro de las zonas)
Generador de demostración	Listados de renta INVENTADOS, con 5 % inflados y 3 % de subprecio sembrados (no se versionan)	28,772 anuncios

5. Calidad del producto: ISO/IEC 25010:2023

ISO/IEC 25010:2023 define un **modelo de calidad del producto** de software con 9 características. Es un modelo de referencia, no una certificación: la tabla es una **autoevaluación del equipo**, con la evidencia que existe en el repositorio y las brechas que reconoce. (La edición de 2023 sustituye a

la de 2011, pasa de 8 a 9 características y renombra «Usabilidad» como «Capacidad de interacción».)

Característica (subcaracterísticas)	**Evidencia en CIVITAS**	**Brecha reconocida**
Adecuación funcional (completitud, corrección, pertinencia)	H6 y RF-1.1 a RF-1.4 implementados; el motor etiqueta el 100 % de los anuncios con superficie; la consistencia de INEGI se verifica (0 claves, nombres o municipios incoherentes; 99.6 % de zonas con población)	Precios de demostración; recall de 53.2 %; muestra de validación sembrada; entrevistas y Plan B sin completar
Eficiencia de desempeño (comportamiento temporal, uso de recursos, capacidad)	Búsqueda, autocompletado y comparación con p95 de 174 ms en el servidor sobre 2,503 zonas; 50 usuarios simulados con 0 errores y p95 de 1,571 ms (meta <2,000 ms); contorno simplificado en PostGIS y descargado aparte del HTML	Medido en el servidor; 300 solicitudes tardaron 4,521 ms, más que en el MVP-5 por el catálogo de 2,503 zonas y 28 mil anuncios; sin medición por red; la meta de miles de usuarios no se verifica
Compatibilidad (coexistencia, interoperabilidad)	Un parser aislado por fuente; formatos estándar (GeoJSON, CSV); contrato OpenAPI con `/municipios`, `/anomalias/resumen`, `?anomalia` y `?simplificar`	La referencia de precio pasó de ciudad a municipio con respaldo al estado (cambia el significado del campo); `docs/openapi.json` no se regenera en CI
Capacidad de interacción (reconocibilidad, aprendizaje, operabilidad, protección contra errores, inclusividad, autodescriptividad)	Glosario con «?» (tooltip verificado con teclado), frase de lectura, etiquetas con color, símbolo y texto, menú móvil que cierra con Escape, foco visible, reducción de movimiento, comparador que funciona sin JavaScript, avisos de datos de demostración	Sin auditoría formal de accesibilidad (WCAG), sin pruebas con usuarios reales ni en un móvil físico
Fiabilidad (ausencia de fallos, disponibilidad, tolerancia a fallos, recuperabilidad)	347 pruebas, de ellas contra PostGIS real; el mapa muestra un error con «Reintentar» si falla la descarga; el checklist reprueba datos incoherentes (probado); healthchecks y reinicio automático; migraciones transaccionales con checksum	Sin respaldo ni restauración probados; una sola instancia; sin monitoreo; Overpass de OpenStreetMap responde 502 de forma intermitente (el script reintenta)
Seguridad (confidencialidad, integridad, no repudio, responsabilidad, autenticidad, resistencia)	Ver la sección 6: roles con 401/403 comprobados en el smoke, contraseñas con scrypt, sesiones opacas hasheadas, SQL parametrizado, restricciones CHECK, DENUE sin datos de contacto	Sin bitácora de auditoría (no repudio); sin CSP; limitador de intentos en memoria; dependencias con 3 avisos moderados
Mantenibilidad (modularidad, reutilización, analizabilidad, modificabilidad, capacidad de prueba)	Motor como funciones puras con pruebas; módulos NestJS por dominio; migraciones 011 y 012 nuevas e inmutables; documentación del método en `docs/mvp6/MVP6.md`; checklist ejecutable por hito; 22 suites	Cobertura de código no medida; el generador de la demo y el motor comparten supuestos (sección 7)
Flexibilidad (adaptabilidad, escalabilidad, instalabilidad, sustituibilidad)	Instalación con Docker Compose en un comando; `--estado-completo`, `--cve-mun`, `--umbral` y `--etiquetas`; configuración por variables de entorno (`CIVITAS_ETIQUETAS_PATH`, `CIVITAS_MUNICIPIOS_PATH`); parsers sustituibles	El limitador en memoria y la recaptura de un solo proceso impiden escalar a varias instancias sin cambios; cada municipio nuevo depende de que INEGI publique sus AGEB
Safety (seguridad operacional)	No aplica: CIVITAS es un sistema informativo que no controla procesos físicos ni puede poner en riesgo a personas, bienes o el ambiente	—

6. Seguridad: IEEE Center for Secure Design

El Center for Secure Design de la IEEE Computer Society publicó en 2014 el informe técnico «Avoiding the Top 10 Software Security Design Flaws». **No es una norma formal de la IEEE**, sino una guía de diseño con 10 recomendaciones. Se usa aquí como lista de verificación de diseño (no de código). Como en la sección anterior, la tabla es una autoevaluación del equipo, no una auditoría ni una certificación.

Recomendación	Cómo la atiende CIVITAS (dónde)	Brecha reconocida
1. Ganar o dar confianza, nunca asumirla	La API valida toda entrada del cliente (`parseFiltrosZonas` con `simplificar` entre 0 y 0.01, el filtro `anomalia`, `parseIdsComparacion`: 400 sin tocar la BD); la búsqueda del comparador se resuelve en el servidor y limita su longitud; la web no decide permisos	Sin límite de peticiones ni de registros por IP
2. Autenticación que no se pueda eludir ni alterar	Un solo `SesionGuard`; contraseñas con scrypt y sal, comparación en tiempo constante; token aleatorio de 256 bits guardado solo como SHA-256; cierre de sesión que revoca; el smoke ahora recorre registro, `/auth/me`, cierre y el 401 del token usado	El bloqueo vive en memoria (se reinicia, una instancia); cuentas de demostración con contraseñas triviales (apagadas con dominio real); sin segundo factor, verificación de correo ni recuperación de contraseña
3. Autorizar después de autenticar	`@Roles('administrador')` en `/admin` y en todo `/entrevistas`: 401 sin sesión y 403 sin el rol; el smoke comprueba ahora el 403 de un usuario normal en `/admin/resumen`	Solo dos roles; no se vuelve a autenticar para acciones sensibles
4. Separar estrictamente datos e instrucciones	SQL parametrizado en toda la API (la tolerancia de `simplificar` y la etiqueta de `anomalia` entran como parámetros); el orden de las consultas sale de una lista blanca; los comodines de LIKE se escapan; las etiquetas de Leaflet escapan el HTML	—
5. Validar explícitamente todos los datos	Funciones `parse*` por endpoint, con rechazo probado, más restricciones CHECK en la base (población y viviendas no negativas, etiqueta de anomalía, nivel y umbral) como defensa en profundidad	La validación está repartida por endpoint (no hay un esquema central)
6. Usar la criptografía correctamente	Solo el módulo `crypto` de Node (scrypt, randomBytes, timingSafeEqual, SHA-256), sin criptografía propia; TLS automático con Caddy y HSTS	scrypt con N=2^14, r=8, p=1 está por debajo del mínimo que cita OWASP (por confirmar en la guía); rotación de secretos sin documentar
7. Identificar los datos sensibles y cómo tratarlos	Privacidad por diseño: los listados no tienen teléfono ni anunciante; la tabla de anomalías guarda solo derivados del precio; el DENUE se guarda **sin teléfono, correo, sitio web ni razón social** antes de subirlo al repositorio; `/auth/me` no expone el hash; el panel de administración no muestra correos	El archivo original del DENUE trae esos datos: el script lo descarga, lo recorta y lo borra, pero pasa un momento por el disco; el aviso de privacidad no está validado legalmente; sin política de retención ni borrado a petición
8. Considerar siempre a los usuarios	Mensajes de error claros en español, con «Reintentar» si el mapa no carga; etiquetas que aclaran que un precio fuera de lo normal «no prueba un abuso»; avisos visibles de datos de demostración por capa	Sin pruebas de usabilidad de las pantallas de seguridad

Recomendación	Cómo la atiende CIVITAS (dónde)	Brecha reconocida
9. Entender cómo los componentes externos cambian la superficie de ataque	El mapa base viene de OpenStreetMap (`tile.openstreetmap.org`): desde el rediseño el navegador sí pide teselas a un tercero, con atribución y en grises; INEGI y Overpass solo se consultan al regenerar datos, no al ejecutar la plataforma; `pnpm install --frozen-lockfile`; auditoría de dependencias de este hito: 3 moderadas	Las 3 restantes piden saltar a NestJS 11 (y file-type 21); la auditoría no corre en el CI; la política de uso de las teselas de OSM es para tráfico moderado
10. Ser flexible ante cambios futuros de objetos y actores	Interruptor `DEMO_USERS`; sesiones revocables; migraciones versionadas e inmutables; el formato del hash (`scrypt$N$r$p$…`) guarda sus parámetros; el umbral del motor se guarda con cada veredicto	Sin proceso para re-hashear al subir los parámetros ni para rotar secretos

6.1 Otras brechas de seguridad

- **Sin política de contenido (CSP):** `next.config.mjs` fija HSTS, nosniff, X-Frame-Options y Referrer-Policy, pero no CSP.
- **Swagger público:** la documentación de la API en `/api/docs` está abierta; conviene restringirla en producción.
- **Sin bitácora de auditoría** de acciones de administración.
- **Cuentas de prueba:** el smoke crea una cuenta nueva en cada corrida y no hay un endpoint para borrarlas; por eso no corre contra producción ni con `REQUIRE_HTTPS=1`.

6.2 Auditoría de dependencias de este hito

`pnpm audit --prod` se corrió de nuevo en este hito. En este sprint no se actualizaron dependencias, así que el resultado es el mismo que dejó el MVP-5: **3 vulnerabilidades moderadas**, ninguna crítica ni alta. Dos son de `file-type` (un ciclo infinito en el lector ASF y una bomba de descompresión ZIP; llega por `@nestjs/common`) y una de `@nestjs/core` (neutralización incorrecta de caracteres especiales). Las tres se corrigen con una versión mayor (NestJS 11, file-type 21), que no cabe en este sprint.

Antes → después	Críticas	Altas	Moderadas	Bajas
pnpm audit --prod	0 → 0	0 → 0	3 → 3	0 → 0

6.3 Aseguramiento: ISO/IEC/IEEE 15026-4

La norma ISO/IEC/IEEE 15026-4:2021 (aseguramiento en el ciclo de vida) da guía para demostrar que se cumple una afirmación de aseguramiento sobre un sistema. Los checklists ejecutables de cada hito (`etl mvp2` a `mvp6`) funcionan de forma parecida: cada criterio es una afirmación (p. ej. «el motor etiqueta al menos el 95 % de los anuncios») respaldada por evidencia que se guarda en la base y se reproduce con un comando. No es un caso de aseguramiento formal en el sentido de la norma: no hay estructura argumentativa ni niveles de integridad.

7. Desviaciones y Pendientes

7.1 Hallazgos y correcciones

- **El motor no alcanzaba la meta.** La primera versión comparaba cada anuncio con su municipio y mezclaba tipos de inmueble: midió 45.7 % de precisión y 58.9 % de recall, y el checklist la reprobó. La causa: las diferencias normales entre zonas caras y baratas, y entre cuartos y departamentos, se leían como anomalías. Se corrigió quitando el efecto del tipo y las recámaras, trabajando en escala logarítmica y comparando dentro de la misma zona: 86.9 %. **No se bajó la meta de 85 % para aprobar.**
- **Política de calibración.** El umbral se elige por precisión (el más bajo que cumple 85 %) y no por F1, porque una falsa acusación de «inflado» cuesta más que una omisión. El costo es un recall de 53.2 %.
- **INEGI.** Las claves de AGEB se repiten entre municipios, así que el nombre de cada zona se calcula con municipio, localidad y AGEB. 13 AGEB llegaron de INEGI sin nombre de municipio (se completó con el catálogo) y 10 sin población (se guarda nula, no cero).
- **Truncado silencioso.** Con 2,503 zonas, el selector del comparador y el tope de 200 resultados dejaban zonas fuera sin ningún error; se subió el tope, se simplificó el contorno en PostGIS y el selector se cambió por una búsqueda.
- **Datos de contacto en el DENUE.** El archivo original trae teléfono, correo y sitio web de cada negocio. El ETL no los lee, pero al subir los datos al repositorio habrían quedado publicados: el script ahora guarda el DENUE recortado (de 37 a 13 MB) y se comprobó que el ETL da exactamente los mismos resultados.
- **Tabla cortada en la ficha.** La columna «De dónde sale» quedaba oculta por el desborde de la tabla con la columna nueva de referencia; se corrigió y se verificó en navegador.
- **Smoke.** No iniciaba sesión y por eso no cubría nada autenticado; ahora sí. El bloque nuevo no corre contra la URL pública del despliegue, para no crear cuentas en producción.
- **Referencia de precio.** El campo de ciudad pasó a ser el municipio oficial; el «lugar» y la comparación se calculan dentro del municipio, con respaldo al estado si tiene menos de 5 zonas con precios.
- **Pruebas.** Se actualizaron dos pruebas de contrato (listados con municipio y etiqueta, y tope del mapa) y una que llamaba al comparador con la firma anterior.

7.2 Pendientes

- **Precios reales de renta** (captura manual del ADR-002 o un convenio con un portal). Mientras tanto, las anomalías demuestran el método, no el mercado de Puebla.
- **Muestra etiquetada por personas** (el plan prevé 60 listados) para reemplazar la sembrada: es la validación débil que el propio plan señala.
- Registrar las **5 entrevistas** de precio (3 inquilinos o estudiantes y 2 inmobiliarias o administradoras) y redactar el **Plan B** del MVP-5. Hasta entonces `etl mvp5` no aprueba.
- **Transporte:** OpenStreetMap solo trae paradas, no rutas ni horarios, y 2,280 de las 2,503 zonas (91 %) no tienen ninguna; buscar un GTFS oficial.
- **Dependencias:** migrar a NestJS 11 para cerrar las 3 moderadas y correr `pnpm audit` en el CI.

- Verificar el comparador y la latencia en un despliegue público con `CIVITAS_URL`, y probar la interfaz en un dispositivo móvil físico.
- Cerrar las brechas de seguridad de la sección 6: CSP, Swagger en producción, límite de peticiones y registros, bitácora de auditoría, parámetros de scrypt y rotación de secretos.
- Siguiente hito del plan (MVP-7): badge de anomalía validado con el informe de precisión sobre una muestra humana y corrección de falsos positivos.

8. Referencias

- INEGI, Marco Geoestadístico (diciembre de 2025) y servicio web del Catálogo Único de Claves Geoestadísticas (wscatgeo): https://www.inegi.org.mx/temas/mg/
- INEGI, Censo de Población y Vivienda 2020, resultados por AGEB urbana: https://www.inegi.org.mx/programas/ccpv/2020/
- INEGI, Directorio Estadístico Nacional de Unidades Económicas (DENUE), descarga masiva: https://www.inegi.org.mx/app/descarga/
- OpenStreetMap contributors, paradas y mapa base (licencia ODbL): https://www.openstreetmap.org/copyright
- Leys, C., Ley, C., Klein, O., Bernard, P. y Licata, L. (2013), Detecting outliers: Do not use standard deviation around the mean, use absolute deviation around the median, Journal of Experimental Social Psychology, 49(4).
- Wilson, E. B. (1927), Probable inference, the law of succession, and statistical inference, Journal of the American Statistical Association, 22(158). (Intervalo de confianza de la precisión.)
- ISO/IEC 25010:2023, Systems and software engineering — Systems and software Quality Requirements and Evaluation (SQuaRE) — Product quality model: https://committee.iso.org/standard/78176.html
- IEEE Computer Society, Center for Secure Design, Avoiding the Top 10 Software Security Design Flaws, informe técnico, 2014: https://www.spinellis.gr/pubs/tr/2014-CSD-Flaws/html/CSD-avoid-top10-flaws.html
- ISO/IEC/IEEE 15026-4:2021, Systems and software assurance — Part 4: Assurance in the life cycle: https://www.iso.org/standard/74396.html
- Plan de sprints y criterios por semana: docs/CIVITAS Sprints.md; método y límites del motor: docs/mvp6/MVP6.md; requerimientos y categorías de calidad: docs/FASE_0_CIVITAS.md.